ONE-PAGE BRIEF

Post-quantum cryptography review: cairo @ 68a61f6c6251

Client: StarkWare — public repository (passive review) · Source: github.com/starkware-libs/cairo, commit `68a61f6c6251` · Reviewed: 2026-11-06 13:10 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
Level 0 of 4
no post-quantum cryptography

FINDINGS
2 Critical **6** High **6** Medium
10 Low **4** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

Critical QSI-2026-17951	**zip 0.6.6 is affected by GHSA-m665-v7pm-7grj (CVE-2026-115905)** What to do: Upgrade to a fixed version (9.0.5).
Critical QSI-2026-17954	**zip 0.6.6 is affected by RUSTSEC-2026-0369** What to do: Upgrade to a fixed version (9.0.0).
High QSI-2026-17937	**pulldown-cmark 0.13.4 is affected by RUSTSEC-2026-0414** What to do: Upgrade to a fixed version (0.13.5).
High QSI-2026-17938	**pulldown-cmark 0.13.4 is affected by RUSTSEC-2026-0433** What to do: Upgrade to a fixed version (0.13.6).

20 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium threshold signing and MPC protocols	Pedersen commitment	Track post-quantum threshold signatures (NIST IR 8214C) and keep the protocol layer ready to swap the…
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum…
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 22; unlikely to apply to this build: 2 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 20.

Static review of source code and manifests; files analysed: 563. No requests were sent to the owner's systems.

Full report, content SHA-256: `9fe1603966bd92436044a5bd164e5ed1e014521a75ba3cf960f7d54ead1645b0`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.